

.....  
1055 Budapest  
Tel.: +36 1 391-1400  
ugyfelszolgalat@naih.hu  
Falk Miksa utca 9-11.  
Fax: +36 1 391-1410  
www.naih.hu

Case Number:  
Background:  
NAIH-6427-1/2023  
NAIH/2020/1160/10.  
Subject:  
decision following judicial review  
repeated  
data protection  
authority  
proceeding

## H A T A R O Z A T

The National Authority for Data Protection and Freedom of Information (hereinafter: Authority) has established in the repeated new data protection authority proceeding concerning the data breach reported electronically by Digi Telecommunications and Service Ltd. (registered office: 1134 Budapest, Váci út 35., company registration number: 01-09-667975) (hereinafter: Client or Data Controller) (represented by: [...]) on September 25, 2019, under identification number [...], regarding the fulfillment of obligations set out in Regulation (EU) 2016/679 (hereinafter: General Data Protection Regulation) on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, as well as the repeal of Directive 95/46/EC, initiated on October 8, 2019, based on findings established during the authority inspection, which was officially initiated on December 16, 2019, and closed with decision number NAIH/2020/1160/10, and subsequently in accordance with the judgment number 105.K.704.076/2022/4 of the Metropolitan Court, the following is determined:

1.

It is established that

a. the Client violated Article 5(1)(e) ("storage limitation") of the General Data Protection Regulation when it did not delete the test database involved in the data breach after running the necessary tests and correcting the error. Thus, the large number of customer data stored in the test database was kept in its systems in such a way that the personal data of natural persons could be identified, and the affected individuals remained identifiable for the following one and a half years, even though it no longer needed this data in connection with the provision of its services. The failure to delete the database directly enabled the occurrence of the data breach and the accessibility of personal data.

b. The Client violated Articles 32(1)-(2) of the General Data Protection Regulation, thus it did not implement appropriate technical and organizational measures proportional to the risks regarding the security of data processing, in that

- the content management system used by it ([...]) had a vulnerability that had been known for more than 9 years and could otherwise be detected and fixed with appropriate tools, which allowed access to the databases affected by the incident through the publicly accessible digi.hu website;
- regarding the personal data affected by the data breach, ([...]) did not apply encryption, which significantly increased the risks arising from the incident.

2.

The lack of these measures directly allowed the customer data stored in the databases to become accessible through the vulnerability exploited by the attacking hacker.

2.

The Client is obliged to review all databases containing personal data processed by it to determine whether encryption is warranted and to inform the Authority of the results!

3.

Due to the above violations, the Client is obliged to pay a data protection fine of

80,000,000 HUF, that is, eighty million forints

within 30 days from the date this decision becomes final;

4.

It orders the publication of the final decision with the identification data of the data controller, but with the business secrets redacted.

In case of non-compliance with the request in point 2, the Authority orders the enforcement of the decision, the fine, and the late payment penalty.

There is no administrative remedy against this decision, but it can be contested in an administrative lawsuit with a petition addressed to the Metropolitan Court within 30 days from the notification. The state of emergency does not affect the deadline for initiating the lawsuit. The petition must be submitted electronically to the Authority, which will forward it along with the case documents to the court.<sup>1</sup> A request for a hearing must be indicated in the petition. For those not fully exempt from personal fees, the court review procedure fee is 30,000 HUF, and the case is subject to the fee exemption right. Legal representation is mandatory in the proceedings before the Metropolitan Court.

## REASONING

I.

Background, clarification of the facts

a. The incident report received by the Authority and the findings established during the authority inspection

(1) The Authority initiated an authority inspection on October 8, 2019, regarding the data breach reported electronically by the Client on September 25, 2019, as the data provided in the report were insufficient to assess whether the Client had fully complied with its obligations under the General Data Protection Regulation, particularly those set out in Articles 32-34.

(2) According to the report, the Client became aware no later than September 23, 2019, that an attacker had accessed approximately 322,000 affected personal data by exploiting a vulnerability accessible through the [www.digi.hu](http://www.digi.hu) website, of which a larger part (approximately 297,000

<sup>1</sup> The form for initiating the administrative lawsuit is called NAIH\_K01: NAIH\_K01 form (2019.09.16). The form can be filled out using the general form filling program (ÁNYK program). See: <https://www.naih.hu/kozig-hatarozat-birosagi-felulvizsgalata>

3

(1) The Client's customers and subscribers numbered approximately 297,000 individuals, while a smaller portion (about 25,000 individuals) consisted of newsletter subscribers. Among the personal data of customers and subscribers were the names, mothers' names, places and dates of birth, addresses, personal identification numbers (in some cases personal numbers), email addresses, and landline and mobile phone numbers of the data subjects.

(2) During the official inspection, the Authority summoned the Client to provide statements and documents with its orders numbered NAIH/2019/7105/2 and NAIH/2019/7105/4. Based on the Client's statements, the Authority established the following during the official inspection.

(3) The Client became aware of the attack when the attacking hacker notified them [...]. In their notification, the attacker indicated that, according to their statement, they only requested a row from the affected database as evidence, and their intentions were helpful in nature; therefore, they also

described the technical nature of the error to the Client. Following this, the Client corrected the error, [...].

(4) The majority of the data affected by the incident (approximately 297,000 individuals) was part of a database named "test," created for testing purposes on April 21, 2018. The Client attempted to reconstruct the reason and purpose for creating the test database by examining log files, system alerts, and correspondences. Since the log files and alerts related to the presumed upload time were no longer available, the Client was unable to clearly reconstruct the events. An email from a testing colleague dated April 23, 2018, revealed that an error occurred on April 21, 2018, during which the web servers could not reach the database servers. As a result, the availability of subscriber data ceased. According to the Client's assumption, the data was uploaded to the test database to temporarily eliminate this error and ensure the availability of subscriber data.

(5) The source of the data loaded into the aforementioned test database created to eliminate the error consisted of personal data previously provided by the Data Controller's clients. The clients provided their personal data online or through other sales channels during various service requests [...]. The latest order resulting in the data loaded into the test database was dated [...]. This database contained data provided by approximately 297,000 natural persons.

(6) Following the elimination of the aforementioned error and the restoration of access, the Client believed that the data uploaded to the test database should have been deleted; however, this was omitted due to negligence. The Client was unaware of the accessibility of this data through the aforementioned vulnerability until the attacker's notification. The Client was unable to detect access to the data by the attacker (e.g., based on alerts from network security devices) before the attacker themselves drew attention to it.

(7) Beyond the test database, the discovered vulnerability also allowed the attacker to access another database maintained by the Client behind the digi.hu website, named [...], which contained the personal data of individuals subscribed to the newsletter on the site. Approximately 25,000 natural persons' data (name, email address) was found here. However, based on investigations, the Client asserts that unauthorized access to the specific personal data stored in this database cannot be demonstrated. Nevertheless, due to the vulnerability, the risk of access existed concerning this data as well.

4

(9) The specific vulnerability existed through the [...] page. Here, the vulnerability of the website could be exploited through the "sorting field." The cause of the error that allowed unauthorized access was a security flaw found in the [...]2 content management system used by the Client. This security flaw had been known for more than 9 years and a patch was available for it, which the Client had not installed previously. The reason for this was that the patch was not part of the officially released patch packages for the software. Following the incident, the patch3 was installed.

(10) The Client did not detect any further unauthorized access to the affected data through the security flaw. No other circumstances indicated that anyone other than the hacker could have accessed the data.

(11) The Client also informed the Authority that, in order to prevent similar data protection incidents, it regularly checks the databases it manages to ensure that personal data is processed/stored only for legitimate purposes. The databases are also periodically cleaned, their security is checked, and the applications and data owners associated with them are identified. Furthermore, as a result of additional external examination, it is considering acquiring and operating a higher-level firewall.

(12) The Client has an internal policy that requires the applications it uses to be kept up to date, and they must be regularly checked for this purpose. At the time of the incident, the [...] system (with which the affected database was managed) was using the latest version, but it did not include the unofficial patch that fixed the vulnerability. The vulnerability itself was actually present in the [...] so-called "core." In this regard, the Client stated that since many unofficial patches are released for the official

version, it does not have the capacity to verify them.

(13) Regarding the use of open-source content management, the Client stated that it chose this system because it is free, widely used worldwide, and is continuously tested and supported software.

(14) The Client regularly conducts vulnerability assessments of the systems it uses with the help of the [...] software. However, this assessment did not extend to the digi.hu website until the occurrence of the data protection incident. After the incident, the Client extended the assessment to this website as well.

(15) [...]

(16) The attacker reporting the vulnerability is [...]. The test database named "body" affected by the incident was also deleted by the Client following its awareness of the flaw.

b. Initiation of data protection authority proceedings in the case and further clarification of the facts

(17) Beyond further clarification of the facts, due to the necessary examination of the presumed violation of the obligations set forth in Articles 5 and 32-34 of the General Data Protection Regulation by the Client, regarding the right to informational self-determination and freedom of information.

2 [...]

3 The availability of the installed patch ("patch") is [...]

5

In consideration of Section 60 (1) of Act CXII of 2011 (hereinafter: Infotv.), the Authority decided to initiate a data protection authority procedure on December 16, 2019.

(18) Beyond the findings established during the official inspection, further clarification of the facts became necessary; therefore, the Authority summoned the Client to provide statements and documents with its resolutions NAIH/2020/1160 and NAIH/2020/1160/3, to which the Client responded within the deadline. Based on the Client's statements, the Authority established the following in addition to the circumstances clarified during the official inspection.

(19) The Client presented in detail, with the help of a diagram and description, the structure of the servers and other network elements involved in the incident and the location of the databases.<sup>4</sup> According to this, the data sets affected by the incident were accessible at [...]5 [...] on the affected network (see the diagram below).

[...]

(20) The Client used [...] for the creation and further management of the database.

(21) According to the Client's statement, the personal data stored in the database table affected by the incident were not encrypted. The reason for this, according to the Client's statement, is that the requirement for encryption concerning the [...] databases is not present in the internal regulations.

(22) According to the Client, the database [...] did not consider encryption necessary either, as the protection of personal data is theoretically ensured by restricting access and appropriate authorization allocation, and the application of such encryption could cause problems in the usability and operation of the databases. The Client did not provide a detailed justification for the specific problem.

(23) Contrary to the above statements, the application of encryption in IT systems is generally present in the Client's regulation named [...]. The relevant points of the regulation were sent by the Client to the Authority at its request.

(24) At the request of the Authority, the Client described in detail how the attacker managed to execute the attack and access the personal data stored in the database [...]. The method was explained to the Client by the attacker. Based on this, the attacker executed a so-called [...] attack on the affected digi.hu website. According to the Client, executing this attack is a time-consuming task and can only be carried out purposefully, with the intent of unauthorized access, and its execution requires a high level of technical knowledge. During the attack, the queries executed by the attacker ultimately indicated a

vulnerability on the [...] page, through which a total of 297,649 rows from the [...] based test database became accessible and listable.

4 In the response received on February 10, 2020, to the Authority's resolution NAIH/2020/1160 regarding the clarification of the facts, and in its Annex 1.

5 [...]

6

(25) At the request of the Authority, the Client detailed exactly which data categories were processed in the case of the two separate databases affected by the incident, what the purpose and legal basis for processing this data were, and exactly how many affected personal data were processed.

-

Test database named "test" containing subscriber data: name of the affected person, birth name, mother's name, place and date of birth, address, ID number, occasionally personal identification number, email address, landline and mobile phone numbers, bank account number, data related to the contract, data related to the service used. The purpose of data processing in this case is to conclude the subscriber contract. The legal basis for data processing: Article 6 (1) (b) of the General Data Protection Regulation (the processing of data is necessary for the performance of a contract to which the data subject is a party). A total of 297,649 affected personal data were processed in the database. This number constitutes 32.37% of the Data Controller's residential customers.

-

Live database named "digi.hu" containing data of newsletter subscribers, linked to the digi.hu website: name and email address. The purpose of data processing in this case is to contact the affected individuals for business acquisition with offers provided by the Client (direct marketing). The legal basis for data processing: Article 6 (1) (a) of the General Data Protection Regulation (the data subject has given consent to the processing of their personal data for one or more specific purposes). A total of 25,269 affected personal data were processed in the database. This number constitutes 2.74% of the Data Controller's residential customers.

(26) The Client forwarded to the Authority its data processing regulations related to the management of the data sets affected by the incident and its internal data protection incident management procedures.<sup>6</sup>

(27) The Client provided the Authority with the technical description of the vulnerability that existed on the digi.hu website, which was also communicated to it by the attacker in their message.

(28) The email message sent by the hacker describing the vulnerability reveals that alongside the database named "test" (containing 297,649 data rows), the database named "digi.hu" affected by the incident contains access data related to the digi.hu website in addition to the personal data of the newsletter subscribers. According to the hacker's letter, in this "digi.hu" database, data of a partial/full privileged system administrator user can also be extracted from the [...] database table. This data includes the system administrator's [...]. According to the message, this data could grant access to the administration interface of the digi.hu website.

(29) Based on the above, the hacker's email message illustrates the databases and personal data affected by the incident as shown in the following table:

6 The annexes 2-3 of the response received on February 10, 2020, to the Authority's resolution NAIH/2020/1160 regarding the clarification of the facts.

7

Database Name

Number of Data Subjects

Type of Data

"Test"

297,649 subscribers

Name, birth name, place and date of birth, mother's name, email address, password, mobile phone number, bank account number, identification number, ownership rights (owner or tenant), payment method, data related to payment willingness (e.g., collection), data related to the contract, type of service used, date of service start/end.

"Digihu"

25,269 newsletter subscribers

[...] partial/full rights administrator

Newsletter subscribers: name, email address

Administrators: [...]

c.

First decision made during the data protection authority procedure and its judicial review

(30) Based on the facts described above, the Authority found a violation by the Client, therefore on May 18, 2020, under case number NAIH/2020/1160/10, it issued a decision in which it held the Client liable for violating Article 5(1)(b) and (e) (principles of "purpose limitation" and "storage limitation") as well as Article 32(1)-(2) (security of processing) of the General Data Protection Regulation. As a result, the Authority obliged the Client to review all of its databases containing personal data to determine whether encryption is warranted, and to notify the Authority of the results. Furthermore, due to the established violations, the Authority imposed a data protection fine of 100,000,000 HUF on the Client and ordered the publication of the decision with the Client's identification data.

(31) The Client, through its legal representative, challenged the Authority's decision NAIH/2020/1160/10 before the Metropolitan Court (hereinafter: Court). In the proceedings, the Court initiated a preliminary ruling procedure before the Court of Justice of the European Union (hereinafter: CJEU) for the interpretation of Article 5(1)(b) and (e) of the General Data Protection Regulation.

(32) In its judgment C-77/21, the CJEU stated that it is not contrary to the principle of "purpose limitation" if the data controller records and stores personal data previously collected and stored in another database in a database created for the purpose of conducting tests and correcting errors, provided that such further processing complies with the specific purposes for which the personal data was originally collected, which must be determined in light of the criteria set out in Article 6(4) of the General Data Protection Regulation. At the same time, it considered it contrary to the principle of "storage limitation" if the data controller uses personal data collected for other purposes for the purpose of conducting tests and correcting errors.

8

the created database for a longer period than necessary for the performance of these tests and the correction of these errors.

(33) The Court, taking into account the findings established in the EUB decision, in its judgment numbered 105.K.704.076/2022/4, determined that the Client's action challenging the Authority's decision NAIH/2020/1160/10 was partially well-founded.

The Court's findings regarding the principle of purpose limitation (34-38):

(34) In its judgment, the Court pointed out that it was not disputed between the parties (the Client as the plaintiff and the Authority as the defendant) that the plaintiff Client collected and stored the personal data of its residential customers for the purpose of entering into and fulfilling subscriber contracts, and this original data processing purpose was lawful under Article 6(1)(b) of the General Data Protection Regulation. Additionally, in April 2018, a technical error affecting the operation of the server led to the creation of the Test Database for troubleshooting purposes, resulting in the termination of subscriber data. Although the original data processing purpose was the conclusion and fulfillment of subscriber contracts, this alone did not mean that additional so-called "ancillary purposes" could not be associated with the realization of this purpose, which also results in the principle of

"purpose limitation" being applicable in relation to this "ancillary purpose."

(35) The EUB, in its judgment (in paragraph 35), established that further data processing for another purpose is permissible if the further processing of personal data is compatible with the original purpose of data collection, and to determine this – considering Article 6(4) of the General Data Protection Regulation – several factors must be taken into account, including: the purpose of collecting personal data and the purpose of the planned further processing, the circumstances of the collection of personal data, the nature of the personal data, the possible consequences of the further processing for the data subjects, and the existence of appropriate safeguards. The criteria set out in Article 6(4) of the General Data Protection Regulation are illustrative, and the existence of even a single circumstance among them may be sufficient for compliance with the provisions of Article 5(1)(b) of the General Data Protection Regulation. The EUB also stated in its Judgment (in paragraph 38) that it is the task of the national court to determine the original purpose of data collection and the purpose of further processing, taking into account the aforementioned criteria and the totality of circumstances characteristic of the given case, and if the purpose of further processing differs from the original purpose of data processing, to examine whether the further processing is compatible with the original data collection purpose.

(36) The Court, in light of the EUB judgment and the undisputed facts presented by the parties, established that the plaintiff originally collected and stored the personal data for the purpose of entering into and fulfilling subscriber contracts, and that the direct purpose of creating the Test Database was related to a specific error that had arisen, namely to perform the necessary tests and correct the error. The court further established, in accordance with what is stated in paragraph 44 of the Judgment, that although the Test Database was created for troubleshooting purposes by the plaintiff, it was nonetheless specifically related to the original data processing purpose of the personal data. Testing and correcting errors is clearly necessary for the plaintiff to access the subscriber data and utilize it for the

9

for the conclusion and performance of subscriber contracts, thereby facilitating the realization of the original data processing purpose.

(37) The Authority – in its statement made during the trial, in light of the EUB Judgment – did not dispute the compatibility of the original data processing purpose (conclusion and performance of contracts) and the further data processing purpose (error correction) during the proceedings, and it was not significant that, based on other circumstances to be examined, compatibility could not be established, since even the existence of a single circumstance could justify compatibility.

(38) Based on the above, the Client – with regard to Article 6(4)(a) of the General Data Protection Regulation – processed the personal data of customers in the test database lawfully, in accordance with the provisions of Article 5(1)(b) of the General Data Protection Regulation, in a manner compatible with the original data processing purpose, according to the Court.

The Court's findings regarding the principle of limited storage (39-41):

(39) The Court further stated in its judgment – referring to points 54 and 57 of the EUB decision – that over time, even originally lawful data processing may become incompatible with the General Data Protection Regulation if the data is no longer necessary for achieving the purposes of data processing, and the data must be deleted once these purposes have been fulfilled. Although the purpose related to the creation of the test database was indeed closely related to the original data processing purpose, it was not entirely identical, as it served directly to perform the necessary tests and to correct the errors that arose.

(40) Consequently, compliance with the principle of limited storage regarding the data processing in the test database also needed to be examined in relation to this purpose, and it had to be established that the storage of data in the Test Database was lawful for the duration necessary to perform the tests and to correct the errors. Since the error was rectified in April 2018, and the Client only terminated the

test database in September 2019, the data processing duration of more than one and a half years exceeded the necessary data processing period by an unreasonable length of time. The Client could not demonstrate compliance with this circumstance with the principles set out in Article 5(2) of the General Data Protection Regulation; it acknowledged that it did not delete the test database out of negligence, even though its maintenance was no longer justified by the error correction, and then forgot about the test database until becoming aware of the attack. All of this clearly indicates that the contested data processing no longer had a direct purpose for the Client (but, as stated above, this does not exclude the purpose-bound nature of data processing).

(41) Based on the above, the plaintiff Client's data processing, according to the judgment of the Metropolitan Court, is contrary to the principle of "limited storage" as set out in Article 5(1)(e) of the General Data Protection Regulation.

10

Further Findings of the Court (data security, legal consequences) (42-45):

(42) In addition to the above, the Court found in its judgment that the Authority's original decision NAIH/2020/1160/10 was in violation of the provisions set forth in Article 32(1)-(2) of the General Data Protection Regulation.

(43) The Court further established that, based on the facts, the findings in the Authority's decision do not substantiate a violation of Article 5(1)(b) of the General Data Protection Regulation; therefore, pursuant to Section 89(1)(b) and Section 92(1)(b) of Act I of 2017 on Administrative Court Procedure (hereinafter: Kp.), the decision was annulled concerning the determination of a violation of Article 5(1)(b) of the General Data Protection Regulation. The Court also annulled the parts of the decision that ordered the amount of the imposed fine and the publication of the decision among the legal consequences, and it obliged the Authority to conduct a new procedure regarding the legal consequences. Beyond this, based on Section 88(1)(a) of the Kp., the Court rejected the claim. Due to the differing determination of the violations from that of the Authority, the Court did not examine the claim regarding the assessment of legal consequences on its merits.

(44) In its judgment, the Court stated that in the repeated procedure, the Authority must only reconsider the legal consequences and assess how the absence of a violation of the principle of "purpose limitation" affects the imposition of the fine and the applicability of the decision's publication. If the Authority takes a position on the imposition of a fine in the repeated procedure, it must also consider that this violation does not exist in relation to the Client's examined data processing activities when determining the amount of the fine. In this regard, the amount of the fine imposed cannot reach the 100,000,000 forints imposed in the original authority procedure.

(45) In light of the above-mentioned judgment, the Authority has made the present decision in the repeated authority procedure.

II.

## Applicable Legal Provisions

According to Section 99 of Act CL of 2016 on General Administrative Procedure (hereinafter: Ákr.), the authority – within the limits of its competence – monitors compliance with the provisions laid down in the legislation and the fulfillment of the enforceable decision.

According to Article 2(1) of the General Data Protection Regulation, the General Data Protection Regulation must be applied to the data processing affected by the reported incident.

Article 4(12) of the General Data Protection Regulation defines what constitutes a data protection incident; according to this, a "data protection incident" is a security breach that leads to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data that has been transmitted, stored, or otherwise processed.

11

According to Article 5(1)(b) of the General Data Protection Regulation, the collection of personal data

shall be for specified, legitimate, and clear purposes, and shall not be processed in a manner incompatible with those purposes; [...] ("purpose limitation").

According to Article 5(1)(e) of the General Data Protection Regulation, personal data shall be stored in a form which permits identification of data subjects only for as long as is necessary for the purposes of processing the personal data; [...] ("storage limitation").

According to Article 5(2) of the General Data Protection Regulation, the data controller is responsible for compliance with the principles laid down in Article 5(1) and must be able to demonstrate such compliance ("accountability").

According to Article 6(4) of the General Data Protection Regulation:

If processing for purposes other than that for which the personal data were collected is not based on the data subject's consent or on Union or Member State law which is necessary and proportionate to achieve the objectives laid down in Article 23(1), in order to determine whether the processing for another purpose is compatible with the purpose for which the personal data were originally collected, the data controller shall take into account, among other things:

- a) the purposes of collecting the personal data and any links between those purposes and the intended further processing purposes;
- b) the circumstances of the collection of personal data, in particular the relationship between the data subjects and the data controller;
- c) the nature of the personal data, in particular whether special categories of personal data referred to in Article 9 are processed, or whether data concerning criminal convictions and offenses are processed under Article 10;
- d) the potential consequences for the data subjects of the intended further processing;
- e) the existence of appropriate safeguards, which may include encryption or pseudonymization.

According to Article 17(1)(a) of the General Data Protection Regulation, the data subject has the right to obtain from the data controller the erasure of personal data concerning him or her without undue delay, and the data controller is obliged to erase personal data concerning the data subject without undue delay if [...] the personal data are no longer necessary for the purposes for which they were collected or otherwise processed.

According to Article 32(1)(a) of the General Data Protection Regulation, the data controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, taking into account the state of the art and the costs of implementation, as well as the nature, scope, context, and purposes of the processing, and the risks to the rights and freedoms of natural persons, which are presented by varying degrees of likelihood and severity, including, where appropriate, the pseudonymization and encryption of personal data.

According to Article 32(2) of the General Data Protection Regulation, when determining the appropriate level of security, account shall be taken of the risks arising from the processing, in particular the risks of accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to personal data transmitted, stored, or otherwise processed;

12

resulting from unlawful destruction, loss, alteration, unauthorized disclosure, or unauthorized access to personal data.

According to Article 33 (1)-(2) and (4)-(5) of the General Data Protection Regulation, the data controller shall notify the competent supervisory authority under Article 55 without undue delay and, where feasible, no later than 72 hours after becoming aware of a personal data breach, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. If the notification is not made within 72 hours, the reasons for the delay must also be provided. The data processor shall notify the data controller of the personal data breach without undue delay after becoming aware of it. If and to the extent that it is not possible to provide the information simultaneously, it may be provided later in phases without undue delay. The data controller maintains a record of personal data breaches,

indicating the facts related to the personal data breach, its effects, and the measures taken to remedy it. This record enables the supervisory authority to verify compliance with the requirements of this Article.

According to Section 101 (1) (a) of the Administrative Procedure Act (Ákr.), if the authority detects a violation during an official inspection, it shall initiate its administrative procedure. Based on Section 38 (3) and Section 60 (1) of the Information Act (Infotv.), the Authority shall conduct an official data protection authority procedure ex officio in order to enforce the right to the protection of personal data, in its capacity under Section 38 (2) and (2a) of the Infotv.

According to Section 103 (1) of the Ákr., the provisions of the Ákr. regarding procedures initiated upon request shall be applied with the deviations specified in Sections 103 and 104 of the Ákr.

Pursuant to Section 61 (1) (a) of Act CXII of 2011 on the Right to Informational Self-Determination and Freedom of Information (hereinafter: Infotv.), the Authority may apply the legal consequences specified in the General Data Protection Regulation in connection with the data processing operations defined in Section 2 (2) and (4).

According to Article 58 (2) (b) and (i) of the General Data Protection Regulation, the supervisory authority, exercising its corrective powers, shall reprimand the data controller or data processor if their data processing activities violate the provisions of the regulation, and may impose an administrative fine in accordance with Article 83, depending on the circumstances of the case, in addition to or instead of the measures mentioned in this paragraph. Pursuant to the same Article (2) (d), the supervisory authority, exercising its corrective powers, instructs the data controller or data processor to bring their data processing operations into compliance with the provisions of the regulation – if applicable, in a specified manner and within a specified time frame.

The conditions for imposing an administrative fine are set out in Article 83 of the General Data Protection Regulation. According to Section 75/A of the Infotv., the Authority exercises the powers specified in Article 83 (2)-(6) of the General Data Protection Regulation with regard to the principle of proportionality, particularly by taking action primarily through a warning to the data controller or data processor in the event of a first-time violation of the provisions regarding the processing of personal data as defined in legislation or in mandatory legal acts of the European Union, in accordance with Article 58 of the General Data Protection Regulation. According to Section 104 (1) (a) of the Ákr., the Authority shall initiate proceedings ex officio within its jurisdiction if it becomes aware of circumstances that warrant the initiation of proceedings; according to the same paragraph (3), the ex officio procedure shall commence with the first procedural act.

**\*\*13\*\***

starts on the day of the execution, and the notification of the known client regarding the initiation may be omitted if the authority decides within eight days after the initiation of the procedure.

According to Sections 97 (3)-(4) of the Kp., the administrative authority must conduct the repeated procedure or carry out the administrative act within the deadline established in the final decision, or in the absence of such, within the deadline specified by law. The operative part and reasoning of the court's decision bind the acting administrative authorities in the repeated procedure and during the execution of the act ordered by the court's decision.

**\*\*III. Decision\*\***

a. Applicability of the General Data Protection Regulation

(46) According to Article 99 (2) of the General Data Protection Regulation, the regulation must be applied from May 25, 2018. The test database named "body" affected by the data protection incident was created in April 2018 based on the Client's statement for testing and troubleshooting purposes.

(47) The database named "digi.hu," which contains data related to the digi.hu website, included data of newsletter subscribers for direct marketing purposes and system administrator data that provides access to the website interface, which were not test data but live, up-to-date data.

(48) The Client learned that unauthorized external access to the two aforementioned databases could be exploited through a vulnerability of the digi.hu website at the earliest on September 23, 2019, from an external attacker who uncovered the security flaw. The data processing affected by the incident, namely the storage of customer data in the databases affected by the incident, continued to exist even after the applicability of the General Data Protection Regulation came into effect. Therefore, both the provisions of Article 99 (2) and the provisions regarding the material scope in Article 2 (1) must be applied to the data processing.

(49) Furthermore, it should be noted that for the application of the provisions of the General Data Protection Regulation regarding the handling of data protection incidents, the relevant time is when knowledge of the incident was acquired, as the prescribed legal consequences are tied to this time point by the regulation. From this perspective, the fact of when the test database, which was managed with inadequate data security measures, was created and when data was collected from the data subjects is not a relevant factor. The risks to the rights and freedoms of the data subjects related to both the occurrence of the incident and the inadequate level of data security persisted even after the applicability of the regulation came into effect.

b. Nature of the data protection incident and measures taken by the data controller

(50) Based on the established facts, the Authority found that the Client became aware of the occurred data protection incident at the earliest when the hacker conducting a vulnerability assessment on the affected digi.hu website notified them via email on September 23, 2019. Previously, the Client had no knowledge of the existence of the vulnerability. The vulnerability assessment conducted by the attacker, the

14

The Client was unable to independently detect the listing of data categories in the affected databases and access to the data stored in the test database, thus it became aware of the incident and the vulnerability that enabled it solely based on the notification from the hacker who perpetrated it.

(51) According to Article 4(12) of the General Data Protection Regulation, a data breach is defined as a security breach that results in the unauthorized access to personal data being processed. In this context, the relationship with the security event can be considered a key element. Based on the Client's incident report and the clarification of the facts, it can be established that the attacker was able to access the test database created for testing and troubleshooting purposes, which contains personal data, by exploiting a vulnerability accessible through the digi.hu website maintained by the Client. Therefore, the unauthorized knowledge of personal data could have occurred through the exploitation of an IT security deficiency, which thus resulted in a data breach.

(52) According to Article 33(1) of the General Data Protection Regulation, as a general rule, the data breach must be reported to the supervisory authority. This paragraph of the regulation and the (85) recital also state that the data controller may only refrain from reporting if it can demonstrate, in accordance with the principle of accountability, that the data breach is unlikely to result in a risk to the rights and freedoms of natural persons. Since the general rule is to report the incident to the authorities, exceptions to this rule should be interpreted narrowly.

(53) According to the provisions of recital (75) of the General Data Protection Regulation, if the data processing – in this case, the storage of data of residential customers and system administrators – could lead to identity theft or misuse of identity, it is fundamentally considered to be risky.

(54) Given the data stored in the database created by the Client for testing and troubleshooting purposes (the affected person's name, birth name, mother's name, place and date of birth, address, personal identification number, occasionally personal number, email address, landline and mobile phone numbers, payment and banking data, data related to the requested service), identity theft or misuse of identity could be committed.

(55) Regarding another database linked to the digi.hu website, named "digi.hu," which contains data accessible through the security breach (data for newsletter sending and system administration), the

hacker also indicated the vulnerability of this data, although no specific data was retrieved; only the types of available data concerning the system administrators were listed ([...]). Nevertheless, the deficiencies in security measures, such as the inadequate level of protection against unauthorized access, also existed concerning this data.

(56) Based on the above, the Authority considers the data breach to be risky; therefore, if the data controller becomes aware of such an incident, it must report it.

7 General Data Protection Regulation Article 5(2): The data controller is responsible for compliance with paragraph (1) [principles] and must be able to demonstrate such compliance ("accountability").

15

must be reported to the supervisory authority pursuant to Article 33(1) of the General Data Protection Regulation. The Data Controller made the notification to the Authority on September 25, 2019, thus fulfilling this obligation within 72 hours of becoming aware of the incident. Therefore, the Authority did not establish any violation related to the fulfillment of the reporting obligation.

(57) In connection with the incident, the Data Controller outlined the measures taken to mitigate any potential adverse consequences arising from it. Based on this, the test database was deleted, and a patch was installed that eliminated the vulnerability present in the used [...] system. The Client had already implemented organizational measures prior to the occurrence of the incident to filter out unnecessarily processed data and databases; however, the affected test database had not been detected earlier in this regard. Furthermore, the Client stated that it would consider acquiring higher-level firewalls to increase the level of protection and that it would also extend the regular vulnerability assessments it already conducts to the digi.hu website in the future.

c. Data security measures related to the storage of data affected by the incident

(58) Regarding the security of data processing, Article 32(1) of the Regulation states that, taking into account the state of science and technology and the risks arising, it is the responsibility of the data controller to ensure the security of the data with appropriate technical and organizational measures. This paragraph (1)(a) includes, where applicable, the pseudonymization and encryption of personal data.

(59) According to Article 32(2), when determining the appropriate level of security, specific consideration must be given to the risks arising from data processing, particularly those resulting from the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data that is transmitted, stored, or otherwise processed.

(60) Based on the information provided in the incident notification and the facts established during the subsequent authority inspection and procedure, the occurrence of the data protection incident can be traced back to a long-known and fixable vulnerability that existed in the [...] system used by the Client for content management—through which the databases affected by the incident were also managed—at the time of the incident. According to the Client, this vulnerability was not fixed prior to the occurrence of the incident because the patch for it was not part of the officially released version of the software. The Client does not follow or monitor unofficial patches available for [...] due to the sheer number of unofficial patches being developed for the software, as it claims it does not have the capability to do so. The Client conducts regular vulnerability assessments in the systems it manages; however, this had not extended to the digi.hu website until the occurrence of the incident.

8 The response received on October 24, 2019, to the Authority's fact-finding order NAIH/2019/7105/2, point 6.

9 The response received on December 3, 2019, to the Authority's fact-finding order NAIH/2019/7105/4, point 5.

16

(61) According to the Client's Information Security Policy, [...].

(62) The handling of customer data affected by the incident – based on the provisions of point III./b. of

this decision – can be considered risky based on the content of the data categories. A significantly increasing factor for the risks is that a large number of personal data of affected individuals were found in the database managed by the Client:

- “test” named test database: 297,649 affected subscribers, which is a total of 32.37% of the Data Controller's residential customers,
- “digi.hu” named database: 25,269 affected registrants, which is a total of 2.74% of the Data Controller's residential customers, in addition to [...] partial/full administrative access data related to the digi.hu website.

(63) Therefore, these are sensitive data processing activities affecting a total of several hundred thousand individuals, more than one-third of the Data Controller's residential customers, which also represents a significant number of affected individuals in proportion to the Hungarian population. These activities carry significant risks to the rights and freedoms of the data subjects based on the preamble of the General Data Protection Regulation (75). According to Article 32 of the Regulation, it is the obligation of the data controller to implement data security measures proportional to the risks.

(64) The testing and debugging activities carried out by the Client concerning the “test” named customer database would not pose a problem if proportional security measures corresponding to the risks reported by such data processing were also applied simultaneously. The Client's internal information security policies also contain provisions regarding the need to assess risks in advance concerning the systems used, mapping previous security gaps and available fixes, as well as applying appropriate encryption. Furthermore, the systems must be regularly examined to identify potential vulnerabilities.

(65) The Client sent the Authority the technical description of the vulnerability present on the digi.hu website, which was communicated to them by the attacker in their message. The Authority's IT security expert examined the description of the vulnerability provided by the attacker and the information communicated by the Client regarding it. This description is included in the information security expert opinion under case number NAIH/2020/1160/5, which was presented to the Client in accordance with Section 76 of the Ákr. by the decision NAIH/2020/1160/7.

(66) According to the findings in the expert opinion, it can be established that the vulnerability identified based on the vulnerability assessment conducted by the attacker is [...] vulnerability. This type of error is characterized by [...]. However, there are web vulnerability scanning applications that can automatically filter out [...] vulnerabilities. For example, the software referenced and used by the Client is widely used for this purpose. The use of these vulnerability scanning software does not require particularly “high-level IT knowledge” or code-breaking ability; their management can be mastered by a person with moderate knowledge of IT security issues after some practice and time investment.

(67) The parameters of the vulnerability assessment described by the attacker indicate that the vulnerability was accessible through the [...] link. At this link, the [...] was vulnerable, meaning that [...] could exploit the [...] vulnerability. The expert examination

17

successfully extractable from the relevant databases (the databases named “test” and “digi.hu”) is the database [...]. Within these, further data can be learned, provided that [...], thus the following can be identified [...] (the specific personal data).

(68) The storage of sensitive data in the database in free text format poses a high-level security issue according to expert opinion, which can be mitigated by using appropriate encryption. The use of [...] mentioned by the Client could have prevented the knowledge of the specific content of the affected [...] database.

(69) The email sent by the attacker, which described the vulnerability, also revealed that data of a partial/full privileged administrator user could be extracted from the “digi.hu” database. This data

includes [...]. The possibility of access to such sensitive, administrator-level data significantly increases the risks of the incident, as possession of this data can easily lead to identity theft, as well as unauthorized access to further data.

(70) The Client submitted their observations and comments to the Authority regarding the above IT security expert opinion after it was presented to them by the Authority in accordance with Section 76 of the Act, under decision number NAIH/2020/1160/7.

(71) Based on this, the Client reiterated that the hacker only requested one row from the "test" database as evidence and stated in their letter that there is no evidence of further unauthorized access. The Authority does not dispute this fact in this decision. The data security deficiencies evaluated in this point of the decision (Chapter III / point c) existed independently of this circumstance concerning all personal data processed in the affected databases, and therefore the reported risks to the data subjects can be linked to all processed personal data.

(72) The Client further emphasized that the high-level IT knowledge required for detecting the vulnerability supports its time-consuming and complex nature. The Authority notes in this regard that the mentioned software capable of uncovering vulnerabilities can automatically detect security gaps, is easily accessible to anyone (in some cases free of charge), and therefore does not require specific code-breaking knowledge from the particular user for its use.

(73) In their statement, the Client again highlighted that since access control to the database is theoretically ensured by permission allocation, they did not find it justified to apply encryption. Furthermore, the encryption of the [...] database table [...] seems incomprehensible to the Client, as there were certain personal data among the affected data (e.g., names, addresses, phone numbers) whose encryption would have caused problems in the applicability and operation of the database in this case. The Client did not elaborate on the reasons for this further. The Authority's findings regarding this can be found in paragraphs (68)-(70) of this decision.

(74) Finally, the Client drew the Authority's attention to the fact that the [...] employee (administrators, users) [...] stored in the affected "digi.hu" database. [...] The Authority does not dispute the above, but notes (in accordance with the findings of the Authority's IT security expert opinion) that regardless of this, the

18

access to other [...] data can be considered a serious factor that increases security risks.

(75) The vulnerability affecting the content management system used by the Client ([...]) has been publicly known for 9 years, along with the solution method to fix it. Related entries were publicly disclosed on the software's official website and its forum.<sup>10</sup> No official patch was created for the bug; however, an unofficial fix was available, which was publicly and freely accessible to anyone.

(76) The security flaw was detected during a vulnerability assessment of the digi.hu website by an external attacker. The software [...] used by the Client for checking other systems was also suitable for this assessment. However, the Client previously neglected to conduct these assessments regarding the website, thus failing to detect the vulnerability. The omission of security assessments for a publicly accessible website visited by clients allowed the vulnerability to remain undiscovered until the specific incident occurred. Regular vulnerability assessments could have filtered out the bug, as evidenced by the investigation of the hacker who discovered this vulnerability. In this regard, the "unofficial" nature of the software component suitable for fixing the existing vulnerability is an irrelevant factor, as it has no significance concerning the existence and detectability of the bug. The Client's internal regulations also prescribe heightened attention and measures regarding the security gaps of the systems used.

(77) For publicly accessible websites on the internet, which can be visited by (potentially numerous) clients, preparedness for possible vulnerabilities is expected to be heightened on the part of the maintainers. This should not pose any particular difficulty for the Client in this case, considering the state of science and technology and the costs of implementation, as well as the Client's position in the market. The Client also took measures after the incident to mandate regular vulnerability assessments

for the website and all other publicly accessible systems on the internet, acknowledging the necessity of such actions.

(78) Therefore, the level of security in managing the databases involved in the incident did not comply with the provisions set forth in Articles 32(1)-(2) of the General Data Protection Regulation, as the long-known, otherwise filterable and fixable security flaw, along with the omission of vulnerability assessments for the digi.hu site, allowed unauthorized access to personal data.

(79) The Client also informed the Authority that no encryption was applied to the personal data in the affected databases ([...]). This is corroborated by the message sent by the hacker, as it indicated that specific personal data became retrievable from the database in a readable format. To prove this, the hacker queried a row from the affected "body" database, which was also communicated to the Client.

(80) The Client's IT Security Policy [...].

(81) The databases were created by the Client using the [...] software, which allows for the [...] encryption of data. Therefore, there was an opportunity to use encryption on the processed personal data concerning the applied technology, and its application would have incurred additional costs.

10 [...]

19

This may mean. Based on the Client's statement, it nevertheless refrains from applying encryption in the databases based on [...] that it manages, thus it did not utilize this option for the databases affected by the incident either. The Client indicated that the protection of personal data is theoretically ensured by restricting access and appropriate authorization allocation, and that the application of such encryption could cause problems in the usability and operation of the databases. The Client did not detail the possible problems.

(82) However, in the absence of encryption, in this case, the majority of the personal data stored in the databases affected by the incident became readable and could be unlawfully accessed. This fact significantly increased the risks to the data subjects in connection with the occurred data protection incident.

(83) The encryption of personal data is generally mentioned in Article 32(1)(a) of the General Data Protection Regulation as an appropriate security measure.

(84) Although the Client did not specify why it considers the encryption of the database [...] problematic in relation to this specific data processing, it must still strive to protect against the leakage of sensitive and large quantities of personal data. The exact reasons for the absence of encryption must be justified according to Article 5(2) of the General Data Protection Regulation.

(85) Since the absence of encryption significantly increased the risks posed to the data subjects by the occurred incident and the security measures applied, the Authority, in order to comply with Article 32(1)(a) of the General Data Protection Regulation and its related internal regulations, has instructed the Client with this decision to review all personal data-containing databases it manages to assess whether the application of encryption is warranted and to inform the Authority of the results – also following the principle of accountability – for the purpose of risk reduction.

(86) In light of the above, the Authority has determined that the Client has not complied with the legal requirements related to data security set out in Articles 32(1)-(2) of the General Data Protection Regulation.

(87) The ascertainability of this infringement is also confirmed by the judgment No. 105.K.704.076/2022/4 issued by the Court.

d. Compliance of the management of the test database affected by the incident with certain principles  
Purpose limitation (88-96):

(88) The principle of "purpose limitation" specified in Article 5(1)(b) of the General Data Protection

Regulation requires that the collection of personal data be for specified, explicit, and legitimate purposes, and that they are not processed in a manner incompatible with those purposes.

20

(89) According to the opinion of the 29th Data Protection Working Group (WP203), the fundamental principle consists of two additional sub-principles, namely, first, the obligation to define the purpose and, second, the obligation related to the use thereof.

(90) In its previous decision NAIH/2020/1160/10, the Authority established that the purpose of creating the database named "test" (error correction) is distinct from the purpose of the original processing of personal data (performance of the contract). According to the previous decision, error correction, as a separate data processing purpose, can be legitimate; however, this separate data processing must also comply with the provisions of the General Data Protection Regulation, including the principle of purpose limitation. The purpose of error correction in relation to the creation of the test database remains until the error itself has been rectified by the Data Controller. According to the previous decision, once the error has been corrected, the separate data processing purpose also ceases, thus, in consideration of Article 17(1)(a) of the General Data Protection Regulation, the test database containing personal data should have been deleted. By unnecessarily retaining the database, the Client's data processing activity, according to the Authority's position expressed in the previous decision, therefore violated the principle of "purpose limitation" specified in Article 5(1)(b) of the General Data Protection Regulation.

(91) In point I/c of the present decision, the Court also referred to judgment no. 105.K.704.076/2022/4, in which it established that the principle of purpose limitation—considering the findings established in the preliminary ruling procedure of the CJEU—was, in its opinion, not violated in relation to the examined data processing, contrary to what was stated in the Authority's previous decision.

(92) The Court indicated that the reason for this was that the Client collected and stored the personal data of its residential customers for the purpose of entering into and performing subscriber contracts, and this original data processing purpose was lawful under Article 6(1)(b) of the General Data Protection Regulation. Associated with this legitimate data processing purpose, there may be so-called "ancillary purposes," which also result in the principle of "purpose limitation" being applicable in relation to this "ancillary purpose."

(93) The data processing for these additional "ancillary purposes" can be lawful if the further processing of personal data is compatible with the original purpose of data collection, considering Article 6(4) of the General Data Protection Regulation. The determination of these criteria in Article 6(4) of the General Data Protection Regulation is illustrative, and the existence of even a single circumstance among them may be sufficient for compliance with the principle of purpose limitation. The CJEU also stated in its Judgment (in paragraph 38) that in the present case, the national court must examine whether the storage of data in the test database deviates from the original purpose of data processing (performance of the contract), and if so, whether the further data processing is compatible with the original data collection purpose.

(94) The Court, considering the CJEU judgment and the undisputed facts presented by the parties, established that the claimant originally collected and stored the personal data for the purpose of entering into and performing subscriber contracts, and that the direct purpose of creating the test database was to perform the necessary tests related to a specific error that had arisen and to correct the error. The court further established, in accordance with what is stated in paragraph 44 of the Judgment, that although the Client created the test database for error correction purposes, it was specifically related to the original data processing purpose of the personal data. Testing and correcting errors is clearly necessary.

21

to enable the claimant to access the subscriber data and use it for the conclusion and fulfillment of subscriber contracts, thereby facilitating the realization of the original data processing purpose.

(95) Based on the Court's judgment, the Client – in accordance with Article 6(4)(a) of the General Data Protection Regulation – lawfully processed the personal data of customers in the test database, in accordance with the provisions of Article 5(1)(b) of the General Data Protection Regulation, in a manner compatible with the original data processing purpose.

(96) In accordance with the provisions of the judgment, the Authority establishes in this repeated procedure that there is no violation of the principle of purpose limitation concerning the processing of the test database involved in the incident.

Limited Storage (97-103):

(97) The principle of "limited storage" specified in Article 5(1)(e) of the General Data Protection Regulation requires that personal data be stored in such a form that identification of the data subjects is possible only for as long as is necessary for the purposes of processing the personal data.

(98) This principle, which is closely related to the principle of purpose limitation, prohibits the storage of personal data that is outdated and no longer usable for any purpose. However, the principle limits the storage period in terms of data storage that allows for the identification of data subjects. The data controller may still store anonymized data, but it must be done in such a way that it is not possible to draw conclusions about the data subject from it, nor to identify them further.

(99) In its previous decision NAIH/2020/1160/10, the Authority established that a violation of the principle of limited storage could also be identified concerning the processing of the test database involved in the incident.

(100) In the judgment referenced in point I/c of the present decision, the Court stated in judgment No. 105.K.704.076/2022/4 – referring to points 54 and 57 of the CJEU decision – that over time, even originally lawful data processing may become incompatible with the General Data Protection Regulation if the data is no longer necessary for achieving the purposes of processing, and the data must be deleted once these purposes have been fulfilled. Although the purpose related to the creation of the test database was indeed closely related to the original data processing purpose, it was not entirely identical, as it served directly to carry out the necessary tests and to correct the errors that arose.

(101) Consequently, the Client had a lawful opportunity to store data in the test database only for the time necessary to perform the tests and to correct the errors. Since the error was rectified in April 2018, and the Client deleted the test database only in September 2019, the data processing period of more than one and a half years exceeded the necessary data processing duration by an unjustifiably long time. The Client could not demonstrate compliance with this circumstance with the provisions of Article 5(2) of the General Data Protection Regulation; it also acknowledged that the test database  
22

did not delete it due to lack of necessity for its retention after the error was rectified, and then forgot about the test database until becoming aware of the attack.

(102) The above – according to the Court's judgment – does not, in itself, exclude the purpose limitation of data processing; however, the contested data processing (error rectification) no longer had a legitimate purpose that could be directly reconciled with the original data collection (contract performance) at the Client. Due to the cessation of the close relationship with the originally reconcilable and therefore legitimate "additional" purpose, the Client no longer had a lawful basis for further storage of the test database in a form that allowed for the identification of the data subjects.

(103) Based on the above, the Authority establishes in this repeated procedure that the Client's further storage of the test database, which is no longer reconcilable with the original legitimate data processing purpose, is unreasonably long and contrary to the principle of "storage limitation" as laid down in Article 5(1)(e) of the General Data Protection Regulation.

e. Findings regarding the applied sanction.

(104) The Authority examined what type of sanction it intends to apply against the Client due to the

identified violations and whether it is justified to impose a data protection fine on them. In this regard, the Authority considered all relevant circumstances of the case in accordance with Article 83(2) of the General Data Protection Regulation and Section 75/A of the Infotv., also taking into account Section 61(5) of the Infotv., and concluded that a mere warning and admonition to the Client is not a proportionate and deterrent sanction, thus imposing a fine is justified.

(105) In determining the necessity of imposing a fine, the Authority weighed the aggravating and mitigating circumstances of the violations as follows:

Aggravating circumstances (106-115):

(106) The data protection incident that occurred at the Client can be traced back to a data security deficiency for which a free fix has long been available on the market, and the vulnerability could have been easily detected even by a third party, thus the Client would have had the opportunity to prevent exposure to unauthorized access to the data long ago if the risks had been properly assessed.

(107) The large number of data involved in the case, the risks posed by their sensitivity, as well as the Client's market position, which increases the expectation for them to apply appropriate data security measures.

(108) As is also reflected in its internal regulations, the risks arising from the use of the (open-source) content management system used by the Client, as well as their assessment, must be carried out by the Client. The Client's failure to take these measures also means that it did not adequately comply with the provisions of its own internal regulations.

(109) The lack of encryption applied to the personal data and the assessment of related risks also increased the risks of exposure to the incident. This

23

The application of measures is also reflected in the Client's relevant internal regulations, which have also not been complied with or have been inadequately fulfilled.

(110) Regarding the digi.hu website, the involvement of personal data of users with administrative (system administrator) rights (see: paragraph (29) and the related table) was considered by the Authority as a factor that significantly increases security risks.

(111) The Authority considers the identified data security deficiencies as a systemic problem, based on which the unlawful situation had long existed at the data controller Client concerning the affected databases even before the incident occurred.

(112) Beyond the data security deficiencies, the occurrence of the incident can be directly traced back to the long-term (one and a half years) storage of the test database created for troubleshooting purposes in a manner that is fundamentally unlawful and suitable for identifying the data subjects. If the test database had been deleted in accordance with the principle of limited storage after the error correction, the risks reported to the data subjects by the incident would have been much milder, as the number of affected data subjects could have been reduced by the number of those included in this test database (297,649 affected). The data security deficiencies would have only existed in the case of personal data processed in the direct marketing database (25,269 affected) and the administrative data of the digi.hu website ([...] affected) if the test database had been deleted in a timely manner.

(113) The identification of outdated, unnecessary data, the cleansing, updating, and necessary deletion of data are also included in the Client's internal regulations, which do not correspond to the circumstances of the management of the test database involved in the incident.

(114) The data security deficiencies and the fundamentally unlawful data processing affected a large number (a total of 322,966 individuals) of personal data, which includes more than two-thirds of the Client's residential customers. This is a significant number relative to the country's population (approximately 3% of the population of Hungary).

(115) In determining the amount of the fine, the Authority took into account that the fundamental

principle violations committed by the Client qualify as violations belonging to the higher maximum fine category according to Article 83(5) of the General Data Protection Regulation.

Mitigating circumstances (116-117):

(116) The Authority considered that no violation related to the processing of personal data had been established against the Client during the period prior to the issuance of the original decision.

(117) The Client also acknowledged in its statement that it should have deleted the test database involved in the incident earlier.

Other circumstances considered (118-119):

(118) After becoming aware of the occurred data protection incident, the Client addressed almost all aspects related to the management of the incident in accordance with Article 33 of the General Data Protection Regulation.

24

The measure prescribed by the Authority was immediately taken, thus the incident was investigated, reported to the Authority within 72 hours from the date of knowledge, the fix eliminating the vulnerability was installed, and the unlawfully processed database was deleted. The internal regulations were modified in connection with the performance of vulnerability assessments. Therefore, the Authority did not identify any issues in the Client's specific data protection incident management practice. The Authority did not specifically consider this behavior as a mitigating circumstance, as it did not exceed the requirements regarding incident management set out in the General Data Protection Regulation (Articles 33-34).

(119) The Authority also took into account that the Client fully cooperated with the Authority during the investigation of the case, although this behavior was also not specifically considered a mitigating circumstance, as it did not exceed the legal obligations.

Client's Economic Weight (120-122):

(120) In determining the amount of the fine, the Authority considered that, according to the publicly available report closing the general business year between January 1, 2018, and December 31, 2018, the Client had a total net revenue of 47,299,383,000 HUF (forty-seven billion two hundred ninety-nine million three hundred eighty-three thousand forints) in that year. The Authority also took into account that, according to the response sent by the Client to the Authority's fact-finding order NAIH/2020/1160/6 regarding the business year between January 1, 2019, and December 31, 2019, the Client had a net revenue of 51,890,528,182 HUF (fifty-one billion eight hundred ninety million five hundred twenty-eight thousand one hundred eighty-two forints).

(121) Finally, the Authority checked the Client's most recent publicly available report closing the business year between January 1, 2022, and December 31, 2022, which indicated that during this period, the total net revenue was 61,763,389,000 HUF (sixty-one billion seven hundred sixty-three million three hundred eighty-nine thousand forints).

(122) In determining the fine, the Authority took into account the business years of 2018 and 2019, considering the period during which the infringement occurred, and also checked the most recent revenue data available to assess the Client's current financial situation. Based on the above, the amount of the imposed fine is proportionate to the severity of the infringement and does not represent an unreasonable financial burden for the Client when compared to previous and current revenue data.

Consideration of the Court's Judgment No. 105.K.704.076/2022/4 (123-126):

(123) The Authority finally noted that the Court stated in its judgment that in the repeated procedure, the Authority must only decide on the legal consequences and must consider that, due to the lack of violation of the principle of "purpose limitation" compared to the original decision NAIH/2020/1160/10, the amount of the fine to be imposed in the repeated procedure cannot reach the 100,000,000 HUF imposed in the original administrative procedure.

(124) Considering all the circumstances of the case, the Authority has decided to reduce the originally imposed fine of 100,000,000 forints by 1/5, resulting in a total fine of 80,000,000 forints. The reason for this is that, although the violation of the principle of purpose limitation cannot be established based on the findings in the judgment regarding the examined data processing, the existence of serious data security deficiencies and the fact of long-term data processing that violates the principles at a fundamental level can still be established. The absence of a violation of one principle (purpose limitation) does not nullify the serious data security deficiencies, the occurrence of data protection incidents attributable to these deficiencies, the violation of another principle (storage limitation), and the risks posed to the privacy of the data subjects in connection with the Client's data processing. Thus, the overwhelming majority of the violations established in the original NAIH/2020/1160/10 decision can still be confirmed in this case (see the following paragraph (125)).

(125) For the purpose of determining the proportionality of the fine amount, the Authority considered the following 5 points of consideration based on the findings in the previous and current decision:

- The violation of data security is attributable to a known, correctable vulnerability for 9 years, thus the measures taken did not meet the state of science and technology (General Data Protection Regulation Article 32(1)). See: the first bullet point of section 1(b) of the operative part of this decision (first finding), as well as particularly the reasoning in paragraphs (60), (75)-(76), and (78).
- Due to the lack of security testing and vulnerability assessment of the website, the data security risks were not adequately assessed (General Data Protection Regulation Article 32(1) and (2)). See: the first bullet point of section 1(b) of the operative part of this decision (second finding), as well as particularly the reasoning in paragraphs (61), (64)-(66), (72), and (76)-(78).
- The lack of adequate encryption significantly increased the data security risks (General Data Protection Regulation Article 32(1)(a) and (2)). See: the second bullet point of section 1(b) of the operative part of this decision, as well as particularly the reasoning in paragraphs (58), (64), (67)-(69), (74), (76)-(77), and (79)-(85).
- The storage of the database affected by the incident violated the principle of storage limitation (General Data Protection Regulation Article 5(1)(e)). See: section 1(a) of the operative part of this decision, as well as particularly the reasoning in paragraphs (97)-(103).
- The storage of the database affected by the incident did not violate the principle of purpose limitation (General Data Protection Regulation Article 5(1)(b)). See: the reasoning in paragraphs (88)-(96) of this decision.

Therefore, taking into account the above points, the Authority imposed a fine proportional to the original fine amount, corresponding to 4/5 of the previous value in this repeated procedure.

(126) Based on points a) and c) of paragraph (2) of Section 61 of the Infotv., the Authority has also ordered the publication of the decision with the Client's identifying data (with the business secrets redacted) again, as the violation remains serious and affects a wide range of individuals. Despite the passage of time since the issuance of the original decision (May 18, 2020), the Authority...

26

considers the public nature of this decision justified, as all previous decisions made during the proceedings (the Authority's previous decision, the CJEU ruling, and the judgment of the Capital Court) are also public documents, and this decision has been made in consideration of those. Furthermore, the assessment of the procedure and the facts from a data protection legal perspective is of theoretical significance from both the authority's and the court's standpoint, containing findings that will also orient future European Union practices, particularly regarding findings related to the principles.

#### IV.

##### Other Issues

The Authority's jurisdiction is defined by Section 38 (2) and (2a) of the Infotv., and its competence extends to the entire territory of the country.

Pursuant to Section 112 and Section 116 (1), as well as Section 114 (1) of the Ákr., there is a right to

legal remedy against the decision through administrative litigation.

The rules of administrative litigation are determined by the Kp. According to Section 12 (2) a) of the Kp., administrative litigation against the Authority's decision falls under the jurisdiction of the court, and based on Section 13 (11) of the Kp., the Capital Court is exclusively competent for the litigation. According to Section 72 of Act CXXX of 2016 on Civil Procedure (hereinafter: Pp.) – applicable based on Section 26 (1) of the Kp. – legal representation is mandatory in cases falling under the jurisdiction of the court. According to Section 39 (6) of the Kp., unless otherwise provided by law, the submission of the statement of claim does not have a suspensive effect on the validity of the administrative act.

According to Section 29 (1) of the Kp. and in consideration of this, Section 604 of the Pp. applies, and according to Section 9 (1) b) of Act CCXXII of 2015 on the General Rules of Electronic Administration and Trust Services (hereinafter: E-Administration Act), the client's legal representative is obliged to maintain electronic communication.

The time and place for submitting the statement of claim are determined by Section 39 (1) of the Kp. Information regarding the possibility of requesting a hearing is based on Sections 77 (1)-(2) of the Kp. The amount of the administrative litigation fee is determined by Section 44/A (1) of Act XCIII of 1990 on Fees (hereinafter: Itv.). The party initiating the proceedings is exempt from the prior payment of the fee under Section 59 (1) and Section 62 (1) h) of the Itv.

According to Section 132 of the Ákr., if the obligated party does not comply with the obligation set forth in the Authority's final decision, it is enforceable. The Authority's decision becomes final upon notification, according to Section 82 (1) of the Ákr. According to Section 133 of the Ákr., enforcement is ordered by the authority that made the decision unless otherwise provided by law or government decree. According to Section 134 of the Ákr., enforcement is carried out by the state tax authority unless otherwise provided by law, government decree, or a local government regulation in a municipal authority matter. According to Section 60 (7) of the Infotv., the Authority carries out the enforcement of the decision regarding the obligation to perform a specific act, to behave in a certain way, to tolerate, or to cease a specific action.

Budapest, June 22, 2023.

Dr. habil. Attila Péterfalvi  
President, Professor Emeritus